Entrega 1 - Proyecto Final ISIA - Phishing en Colombia

Grupo 2

Carlos Daniel Galvis Niño - cgalvisn@unal.edu.co

Johan Muñeton Muñeton - arpsoft273@gmail.com

Ivonne Cristina Ruiz Páez - icruizp@unal.edu.co

Brian Steve Garnica Sandoval - estibitocaneca@gmail.com

Profesores:

Oscar Armando Ortiz

Liliana Olarte

Universidad Nacional de Colombia

Bogotá, Colombia

Diplomado DevOps e IA para Ingeniería de Software

2026

1. Definición del Problema y Contexto de Negocio

1.1 Descripción del Problema

El phishing basado en sitios web en Colombia representa un problema creciente de seguridad digital que afecta tanto a usuarios individuales como a organizaciones, especialmente en sectores como banca, fintech, comercio electrónico y servicios. Este tipo de fraude consiste en la creación y distribución de sitios web maliciosos que simulan ser legítimos, con el objetivo de engañar a los usuarios para que interactúen con ellos bajo una falsa percepción de confianza. El problema se agrava debido al aumento constante de registros de nuevos dominios, lo que facilita la aparición de sitios fraudulentos que pueden estar activos durante ventanas de tiempo cortas pero suficientes para causar impacto.

Los ataques de phishing basados en URLs operan principalmente mediante la generación de sitios web que aparentan pertenecer a entidades legítimas. Estas URLs son diseñadas cuidadosamente para imitar dominios oficiales o para incluir elementos que generen confianza o urgencia en el usuario. Una vez el usuario accede al sitio, se enfrenta a interfaces visualmente similares a las originales, lo que incrementa la probabilidad de interacción. Desde el punto de vista del sistema a diseñar, el vector crítico es la URL misma, ya que contiene información estructural y semántica que puede revelar patrones de fraude antes de que el usuario interactúe completamente con el contenido del sitio.

Desde una perspectiva técnica, existen múltiples factores relevantes en la construcción de estas URLs maliciosas. El typosquatting es una de las técnicas más comunes, donde los atacantes registran dominios con variaciones mínimas de marcas reconocidas (por ejemplo, sustitución de caracteres, adición de subdominios o uso de TLDs alternativos). Adicionalmente, se emplea ingeniería social directamente en la URL mediante el uso de palabras clave como “seguridad”, “verificación”, “actualización” o “soporte”, que inducen al usuario a confiar en el enlace. También es frecuente el uso de estructuras complejas de subdominios para ocultar el dominio real, así como la inclusión de términos relacionados con marcas colombianas específicas (bancos, billeteras digitales, retailers), aprovechando el reconocimiento de estas por parte de los usuarios.

El impacto de este problema en Colombia es significativo. Para los usuarios, implica riesgo de suplantación de identidad, pérdida de acceso a servicios y afectaciones económicas. Para las organizaciones, especialmente aquellas con presencia digital consolidada, el phishing basado en URLs afecta la reputación de marca, genera desconfianza en los canales digitales y puede derivar en costos operativos asociados a atención de incidentes y gestión de fraude. En sectores como el

financiero, donde la confianza es un activo crítico, la proliferación de dominios fraudulentos que imitan marcas locales representa una amenaza directa a la estabilidad de la relación con los clientes.

A pesar de la existencia de mecanismos generales de detección de phishing, el problema no está completamente resuelto en el contexto colombiano. Una de las principales limitaciones es la velocidad con la que se registran y utilizan nuevos dominios, lo que dificulta su inclusión oportuna en listas negras. Además, muchos enfoques actuales dependen de análisis posteriores a la detección del fraude o de señales que requieren interacción del usuario, en lugar de centrarse en el análisis preventivo de la URL. También existe una brecha en la contextualización local: los sistemas genéricos no siempre consideran particularidades del ecosistema colombiano, como marcas específicas, patrones lingüísticos en español o combinaciones de palabras clave utilizadas en el país. Finalmente, la falta de explicabilidad en algunos sistemas de detección limita su adopción, ya que los usuarios y organizaciones requieren entender claramente por qué una URL es considerada riesgosa.

1.2 Delimitación del alcance del problema

El sistema propuesto se enfocará exclusivamente en la detección de phishing en sitios web mediante el análisis de Dominios y URLs. El monitoreo automático usa dominios recién registrados como entrada principal, mientras que la consulta manual permite analizar URLs completas.

Alcance:

- Análisis estructural de URLs
- Evaluación de dominios registrados diariamente
- Detección de patrones sospechosos en la URL
- Análisis básico de contenido textual de páginas web
- Enfoque en marcas y entidades del contexto colombiano
- Monitoreo automatizado de dominios recientemente registrados a partir de fuentes públicas

Fuera de alcance:

- Análisis de correos electrónicos
- Análisis de mensajes SMS
- Detección de malware avanzado
- Desarrollo de extensiones de navegador

1.3 Relevancia en el Contexto Colombiano

El problema tiene alta relevancia debido a:

- Crecimiento del uso de plataformas digitales financieras en Colombia
- Incremento de ataques dirigidos a usuarios finales
- Baja capacidad de validación de autenticidad de sitios web por parte de usuarios
- Impacto económico directo derivado de fraudes digitales

Esta situación hace necesario un mecanismo de análisis preventivo y contextualizado al entorno colombiano, capaz de apoyar la identificación temprana de URLs o dominios sospechosos.

1.4 Actores y Stakeholders

Actores

Actor	Tipo	Descripción	Interacción principal con el sistema
Usuario consultante	Externo	Persona que desea verificar si una URL o dominio presenta señales de phishing antes de considerarlo confiable.	Ingresa manualmente una URL y consulta el resultado del análisis con su explicación.
Analista de monitoreo	Interno	Responsable de revisar los dominios detectados como sospechosos, validar hallazgos y dar seguimiento a casos relevantes.	Consulta resultados priorizados, revisa justificaciones del riesgo y decide acciones de seguimiento.
Administrador del catálogo de marcas	Interno	Responsable de mantener actualizado el archivo JSON de marcas, dominios oficiales, palabras clave, términos relacionados y patrones de typosquatting.	Actualiza y controla la información base usada en el análisis de brand protection.
Responsable institucional de seguridad o protección de marca	Interno	Perfil encargado de interpretar alertas relevantes y apoyar decisiones de gestión frente a dominios sospechosos.	Revisa alertas generadas y utiliza la información para gestión preventiva o institucional.
Equipo de comunicaciones o concientización digital	Interno	Área que puede utilizar las alertas validadas para emitir mensajes informativos o de prevención en canales públicos.	Consulta alertas confirmadas para apoyar publicaciones de concientización.

Organización o marca monitoreada	Externo	Entidad cuyos dominios, nombres comerciales o variaciones pueden ser usados en sitios fraudulentos.	Es parte interesada en la detección temprana de dominios sospechosos asociados a su marca.

Stakeholders

1. Usuarios de servicios digitales en Colombia
   Son los principales afectados por sitios fraudulentos que imitan portales de banca, fintech, comercio electrónico, retail y servicios. Requieren resultados comprensibles y consistentes para reducir el riesgo de interacción con URLs sospechosas.
2. Entidades financieras y fintech colombianas
   Tienen alto nivel de exposición por reconocimiento de marca y frecuencia de uso por parte de los ciudadanos. Son stakeholders clave porque la suplantación de sus dominios afecta confianza, reputación y operación.
3. Empresas de comercio electrónico, retail y servicios digitales
   También pueden ser objeto de imitación mediante dominios similares. Les interesa la detección temprana por el impacto reputacional y la posible confusión de los usuarios.
4. Áreas de seguridad de la información de organizaciones colombianas
   Requieren mecanismos de apoyo para identificar dominios sospechosos vinculados con sus marcas o con servicios que usan sus usuarios, con criterios verificables y explicables.
5. Áreas de protección de marca y gestión reputacional
   Son responsables de vigilar usos indebidos del nombre comercial en Internet. El sistema aporta valor como herramienta de priorización de hallazgos basados en similitud de dominios y señales sospechosas.
6. Equipos de atención, fraude o respuesta institucional
   Aunque no ejecutan el análisis técnico directamente, son usuarios indirectos de los resultados cuando se requiere escalar un hallazgo o comunicar medidas preventivas.

1.5. Procesos de negocio

Flujo de monitoreo automático

1. Recepción del listado de dominios de entrada
   El proceso inicia con la carga de un listado diario de dominios recién registrados, proveniente de una fuente definida para el proyecto. (ejemplo. https://www.whoisds.com/newly-registered-domains)
2. Normalización de los dominios a evaluar
   Cada registro se prepara para su análisis mediante una validación básica de formato y estandarización de la URL o dominio.
3. Consulta del catálogo de marcas
   El sistema toma como referencia el archivo JSON de marcas, que contiene dominios oficiales, palabras clave, términos relacionados y patrones de typosquatting.
4. Ejecución del análisis estructural de URL
   Se evalúan características observables del dominio o URL, tales como similitud con

dominios oficiales, uso de subdominios sospechosos, longitud, tokens relevantes y presencia de palabras que generen confianza o urgencia.

5. Evaluación de coincidencia con marcas del contexto colombiano
   El sistema determina si el dominio analizado presenta relación con marcas registradas en el catálogo, especialmente de sectores priorizados como banca, fintech, retail, comercio electrónico y servicios.
6. Aplicación del modelo de scoring basado en reglas
   Se suman los pesos de las reglas cumplidas para producir un puntaje de riesgo consistente y trazable.
7. Clasificación del resultado
   Con base en el puntaje y la evidencia encontrada, el sistema clasifica el caso en un nivel de riesgo definido, por ejemplo bajo, medio, alto o riesgo desconocido cuando la información es insuficiente.
8. Análisis básico opcional de contenido web
   Cuando aplique y sin afectar el rendimiento, se realiza una verificación limitada de contenido estático accesible por HTTP, como título HTML o texto visible acotado. Si falla, el proceso continúa sin detenerse.
9. Generación del resultado explicable
   El sistema registra no solo la clasificación final, sino también la justificación del análisis: reglas activadas, coincidencias encontradas y motivos de la clasificación.
10. Priorización de dominios sospechosos
    Los hallazgos de mayor riesgo quedan disponibles para revisión por parte del analista o responsable institucional.
11. Emisión de alerta
    Cuando un dominio supera el umbral definido, se genera una alerta para uso interno y, en los casos validados, para fines de concientización pública.

Flujo de consulta manual por usuario

1. Ingreso de una URL por parte del usuario
   El usuario proporciona manualmente una URL o dominio que desea verificar.
2. Validación básica de entrada
   El sistema comprueba que la URL tenga una estructura válida o, al menos, que el dominio pueda ser procesado.
3. Análisis del dominio frente al catálogo de marcas
   Se compara la entrada con dominios oficiales, términos relacionados y patrones de similitud definidos en el catálogo.
4. Evaluación de señales sospechosas en la URL
   Se revisan elementos como typosquatting, longitud atípica, uso de subdominios engañosos y presencia de palabras de manipulación o aparente legitimidad.
5. Aplicación del scoring de riesgo
   El sistema calcula el puntaje usando las reglas definidas y genera una clasificación consistente.
6. Análisis básico opcional de contenido estático
   Si la URL es accesible y el tiempo lo permite, se realiza una verificación limitada de contenido para reforzar la evaluación. Si no es posible, el sistema conserva el análisis parcial.
7. Presentación del resultado al usuario
   El sistema devuelve el nivel de riesgo junto con una explicación clara de los factores que influyeron en la clasificación.

8. Manejo de excepciones sin interrumpir la consulta
   Si existen errores HTTP, redirecciones, inaccesibilidad o timeout, el sistema informa la limitación y entrega el mejor resultado posible con la evidencia disponible.
9. Consulta de trazabilidad del análisis
   El usuario puede revisar la justificación del resultado para entender por qué la URL fue clasificada de determinada manera, manteniendo la explicabilidad como criterio central del sistema.

1.6 Reglas de Negocio

RN-01. Validación de entrada de URL
Toda URL o dominio ingresado debe cumplir con una estructura mínima válida (presencia de dominio y TLD). En caso contrario, el sistema debe rechazar el análisis indicando entrada inválida.

RN-02. Normalización del dominio
El sistema debe extraer y normalizar el dominio principal (removiendo protocolos, parámetros y fragmentos) para garantizar consistencia en el análisis.

RN-03. Comparación con dominios oficiales
El sistema debe comparar el dominio analizado contra el listado de dominios oficiales del catálogo de marcas.

- Coincidencia exacta → no genera alerta por suplantación.
- Coincidencia parcial o similar → activa reglas de análisis de riesgo.

RN-04. Detección de typosquatting
Si el dominio presenta variaciones respecto a un dominio oficial (sustitución, omisión, adición o transposición de caracteres), según patrones definidos en el catálogo, se debe asignar un puntaje de riesgo proporcional a la similitud detectada.

RN-05. Evaluación de palabras clave de marca
Si la URL contiene palabras clave principales asociadas a una marca (ej. nombre de banco o fintech), se debe activar una regla de riesgo por posible suplantación.

RN-06. Evaluación de palabras secundarias y relacionadas
Si la URL incluye palabras secundarias o relacionadas (ej. “pago”, “clientes”, “servicio”), se debe incrementar el puntaje de riesgo en menor proporción que las palabras principales.

RN-07. Detección de palabras de ingeniería social en URL
La presencia de términos que generen urgencia o confianza (ej. “seguridad”, “verificación”, “actualizar”, “soporte”) debe incrementar el riesgo al sugerir manipulación del usuario.

RN-08. Análisis de estructura de subdominios
El uso de múltiples subdominios o estructuras engañosas (ej. “marca.seguridad.ejemplo.com”) debe ser considerado como señal de riesgo, especialmente si el dominio raíz no coincide con el oficial.

RN-09. Evaluación de longitud de la URL
URLs con longitud significativamente superior a un umbral definido deben incrementar el riesgo, dado que pueden ser utilizadas para ocultar el dominio real o confundir al usuario.

RN-10. Evaluación de TLD no habitual
Si el dominio utiliza un TLD distinto al utilizado oficialmente por la marca (ej. uso de ".xyz" en lugar de ".com.co"), se debe aumentar el puntaje de riesgo.

RN-11. Análisis básico de contenido web (opcional)
Si la URL es accesible dentro del tiempo límite:

- Presencia de nombre de marca en el título HTML o texto visible → incrementa el riesgo.
- Ausencia de contenido relevante o error → no detiene el proceso, pero limita la evidencia.

RN-12. Aplicación del modelo de scoring
Cada regla activada debe sumar un peso predefinido. El puntaje total determina la clasificación final del riesgo (bajo, medio, alto).

RN-13. Clasificación determinística del riesgo
El sistema debe asignar siempre la misma clasificación ante las mismas condiciones de entrada y reglas, garantizando consistencia.

RN-14. Manejo de información incompleta
Si la URL no puede ser accedida o analizada completamente, el sistema debe continuar con el análisis disponible y, si es necesario, clasificar como "riesgo desconocido" con justificación.

RN-15. Priorización de marcas colombianas
Las reglas relacionadas con marcas del catálogo deben tener mayor peso en el scoring cuando correspondan a sectores críticos en Colombia (banca, fintech, retail, e-commerce, servicios).

RN-16. Generación de explicación del resultado
Cada resultado debe incluir:

- Reglas activadas
- Evidencia encontrada (ej. coincidencia de dominio, palabras clave)
- Justificación del nivel de riesgo asignado

RN-17. Trazabilidad del análisis
El sistema debe permitir relacionar el resultado final con las reglas específicas que contribuyeron al puntaje, garantizando auditabilidad.

RN-18. Generación de alertas para dominios sospechosos
Los dominios clasificados con riesgo alto deben ser marcados para revisión y posible generación de alertas informativas.

1.7 Restricciones

Restricciones Técnicas

RT-01. Tiempo de respuesta
El análisis completo de una URL no debe superar los 10 segundos.

RT-02. Límite de análisis de contenido web
El análisis de contenido debe tener un timeout máximo de 2 segundos y ser opcional.

RT-03. No ejecución de JavaScript
El sistema solo debe analizar contenido estático obtenido mediante solicitudes HTTP simples.

RT-04. Procesamiento determinístico
El sistema debe producir resultados consistentes ante la misma entrada y configuración.

RT-05. Configuración externa de reglas
Las reglas, pesos y catálogo de marcas deben ser configurables sin modificar el código fuente.

RT-06. Manejo de errores robusto
El sistema debe manejar correctamente:

- URLs inaccesibles
- Errores HTTP
- Redirecciones
- Timeouts

Sin interrumpir el flujo general.

RT-07. Escalabilidad básica para procesamiento por lotes
El sistema debe poder procesar listados diarios de dominios sin degradación significativa del rendimiento.

RT-08. Limitación del alcance funcional
El sistema no debe extenderse a análisis fuera de URLs (ej. archivos, scripts, comportamiento dinámico).

RT-09. Estandarización de salidas
Todos los resultados deben seguir un formato uniforme que incluya: URL analizada, nivel de riesgo, puntaje y justificación.

RT-10. Mantenibilidad del catálogo de marcas
El archivo JSON de marcas debe poder actualizarse de forma controlada y versionada para garantizar consistencia en el análisis.

Restricciones Normativas (Colombia)

RNOR-01. Protección de datos personales (Ley 1581 de 2012)
El sistema no debe recolectar, almacenar ni procesar datos personales. El análisis debe limitarse exclusivamente a URLs y dominios públicos.

RNOR-02. Principio de finalidad y minimización de datos
El sistema debe procesar únicamente la información estrictamente necesaria para el análisis de URLs, evitando cualquier recolección adicional.

RNOR-03. Uso responsable de información pública
Los dominios analizados deben provenir de fuentes públicas o legítimas, sin violar términos de uso de terceros.

RNOR-04. Transparencia en resultados
Los resultados deben ser explicables y no inducir a error, evitando afirmaciones categóricas sin evidencia suficiente.

RNOR-05. No atribución legal automática
El sistema no debe declarar de forma definitiva que un sitio es fraudulento; solo debe indicar niveles de riesgo basados en evidencia técnica.

1.8 Justificación de la No Existencia de Solución Equivalente

Las soluciones gratuitas actuales presentan limitaciones como:

- Falta de enfoque en el contexto colombiano
- Baja capacidad para detectar phishing altamente contextualizado
- Ausencia de explicaciones claras para el usuario
- Dependencia de consultas manuales sin monitoreo proactivo
- Dependencia de listas negras o detección posterior
- Dificultad para reaccionar a nuevos dominios.
- Falta de contextualización en español y marcas colombianas

Por otro lado, soluciones comerciales especializadas suelen ser costosas y no accesibles para usuarios individuales.

- El sistema propuesto introduce como valor diferencial:
- Monitoreo automatizado de dominios nuevos
- Enfoque en marcas colombianas
- Explicabilidad en los resultados
- Accesibilidad sin costo

2. Análisis de Requerimientos

2.1 Requerimientos Funcionales (RF)

1. Núcleo del sistema

Corresponde a los requerimientos esenciales para que el sistema pueda recibir una entrada, analizarla, calcular el riesgo y producir un resultado consistente y explicable.

- **RF1.** Registro de URL para análisis manual
- **RF2.** Validación de datos de entrada
- **RF3.** Normalización de la URL
- **RF4.** Análisis estructural de la URL
- **RF5.** Comparación con dominios oficiales de marca
- **RF6.** Detección de similitud de dominio
- **RF7.** Detección de patrones de typosquatting
- **RF8.** Detección de palabras clave principales de marca
- **RF9.** Detección de palabras secundarias y relacionadas
- **RF10.** Detección de términos sospechosos de manipulación
- **RF11.** Evaluación del TLD del dominio
- **RF14.** Cálculo de puntaje de riesgo
- **RF15.** Clasificación de nivel de riesgo
- **RF16.** Generación de explicación del resultado
- **RF17.** Presentación de evidencia del análisis
- **RF18.** Consulta de resultados de análisis manual
- **RF27.** Uso del catálogo como fuente oficial de referencia
- **RF28.** Manejo de errores de análisis
- **RF29.** Emisión de resultado con análisis parcial
- **RF30.** Estandarización de la salida del análisis
- **RF32.** Visualización de reglas aplicadas por análisis
- **RF37.** Coherencia entre análisis, clasificación y explicación
- **RF38.** Soporte a evaluación determinística

2. Monitoreo

Incluye los requerimientos relacionados con el procesamiento por lotes de dominios recién registrados, priorización de hallazgos y gestión de alertas.

- **RF19.** Carga de listados de dominios para monitoreo
- **RF20.** Procesamiento automático de dominios en lote
- **RF21.** Priorización de dominios sospechosos
- **RF22.** Priorización de marcas del contexto colombiano
- **RF23.** Generación de alertas sobre dominios sospechosos
- **RF24.** Consulta de resultados del monitoreo automático
- **RF31.** Consulta del historial de análisis procesados
- **RF35.** Interfaz para consulta de alertas
- **RF36.** Generación de contenido informativo a partir de alertas

3. Análisis avanzado

Agrupa los requerimientos que amplían el análisis principal con capacidades complementarias, pero no estrictamente indispensables para la primera evaluación estructural de la URL.

- **RF12.** Análisis básico opcional de contenido web estático
- **RF13.** Continuidad del análisis ante información parcial
- **RF25.** Gestión del catálogo de marcas
- **RF26.** Actualización del catálogo de marcas

4. Interfaz

Incluye los requerimientos orientados a la interacción del usuario con el sistema y a la visualización ordenada de resultados.

- **RF33.** Interfaz para consulta manual
- **RF34.** Interfaz para visualización de monitoreo
- **RF35.** Interfaz para consulta de alertas

2.2 Requerimientos No Funcionales (RNF)

Seguridad

- **RNF1.** Validación de entradas
  El sistema debe validar toda URL o dominio ingresado antes de su procesamiento, rechazando entradas malformadas o no procesables.
  Criterio de verificación: en pruebas funcionales, el 100% de las entradas inválidas definidas en los casos de prueba debe ser identificado y rechazado sin interrumpir la operación.
- **RNF2.** Control de solicitudes salientes
  El sistema solo debe realizar solicitudes HTTP/HTTPS necesarias para el análisis básico de contenido estático, sin ejecutar JavaScript ni descargar recursos no esenciales.
  Criterio de verificación: en revisión funcional y técnica, el 100% de los análisis de contenido debe limitarse a peticiones simples de contenido estático.
- **RNF3**. Protección frente a abuso del servicio
  El sistema debe limitar la frecuencia de consultas manuales por usuario o sesión para evitar uso abusivo o degradación intencional del servicio.
  Criterio de verificación: en pruebas de carga controlada, el sistema debe aplicar restricciones configuradas cuando se supere el umbral definido de consultas por unidad de tiempo.
- **RNF4**. Gestión segura de errores
  Los mensajes de error no deben revelar información sensible sobre lógica interna, configuraciones, rutas del sistema o detalles innecesarios del procesamiento.
  Criterio de verificación: en pruebas de caja negra, el 100% de los errores observables debe mostrar mensajes controlados y comprensibles, sin detalles internos.
- **RNF5.** Registro trazable de eventos de análisis
  El sistema debe registrar los eventos relevantes del análisis, incluyendo URL procesada, fecha y hora, resultado, reglas activadas y estado del proceso.
  Criterio de verificación: el 100% de los análisis ejecutados debe generar un registro consultable y consistente.
- **RNF6.** Integridad de la configuración de reglas y catálogo
  Las reglas de scoring y el catálogo de marcas deben mantenerse en fuentes controladas, versionadas y modificables únicamente por perfiles autorizados.
  Criterio de verificación: toda modificación del catálogo o reglas debe quedar asociada a una versión identificable y a un evento de actualización verificable.
- **RNF7.** Principio de mínimo privilegio
  Los perfiles internos del sistema deben contar únicamente con los permisos necesarios para consultar resultados o actualizar el catálogo según su función.

Criterio de verificación: la matriz de permisos debe demostrar separación de funciones y ser validable mediante pruebas de acceso por rol.

- **RNF8.** Alineación con OWASP para aplicaciones web
  El sistema debe incorporar controles básicos alineados con OWASP para prevenir fallas comunes en aplicaciones web, al menos en validación de entradas, manejo de errores, control de acceso y protección de configuraciones sensibles.
  Criterio de verificación: en revisión de seguridad, los controles definidos deben estar presentes y mapeados explícitamente a riesgos conocidos de OWASP aplicables al alcance del sistema.
- **RNF9.** Minimización de datos
  El sistema no debe almacenar datos personales ni atributos innecesarios; solo debe conservar información estrictamente relacionada con la URL, el análisis y la trazabilidad operativa.
  Criterio de verificación: en revisión de modelo de datos, no deben existir campos destinados a datos personales de usuarios finales.

Rendimiento

- **RNF10.** Tiempo máximo de análisis individual
  El sistema debe completar el análisis de una URL en un tiempo máximo de 10 segundos, incluyendo validación, análisis estructural, scoring y análisis básico opcional de contenido.
  Criterio de verificación: al menos el 95% de los análisis individuales en condiciones normales debe completarse en 10 segundos o menos.
- **RNF11.** Tiempo máximo de análisis de contenido web
  El análisis opcional de contenido estático debe ejecutarse con un tiempo máximo de 2 segundos por URL.
  Criterio de verificación: en el 100% de los casos, la etapa de consulta de contenido debe finalizar por respuesta o timeout dentro del umbral configurado.
- **RNF12.** Continuidad ante fallos externos
  Los errores HTTP, redirecciones no resueltas, inaccesibilidad o timeouts no deben bloquear el flujo general del análisis.
  Criterio de verificación: el 100% de los casos de fallo externo simulados debe producir un resultado parcial o “riesgo desconocido” sin caída del proceso.
- **RNF13**. Procesamiento eficiente por lotes
  El sistema debe procesar listados diarios de dominios manteniendo estabilidad operativa durante ejecuciones continuas de monitoreo.
  Criterio de verificación: en pruebas con lotes representativos definidos para el proyecto, el sistema debe completar el procesamiento sin errores críticos ni interrupciones no controladas.
- **RNF14.** Uso acotado de recursos por análisis
  Cada análisis debe ejecutarse con consumo predecible de recursos, evitando operaciones complejas fuera del alcance definido.
  Criterio de verificación: en pruebas de ejecución, no deben observarse fases de crawling, renderizado de navegador ni ejecución de scripts dinámicos.

Usabilidad

- **RNF15.** Claridad del resultado para el usuario
  El sistema debe mostrar siempre un resultado comprensible que incluya nivel de riesgo, puntaje y explicación de los factores relevantes detectados.

Criterio de verificación: el 100% de los resultados visibles debe incluir esos tres elementos de forma explícita.

- **RNF16.** Consistencia de la interfaz
  La interfaz debe presentar los resultados de análisis manual y monitoreo automático bajo una estructura uniforme de campos, etiquetas y estados.
  Criterio de verificación: en revisión funcional, el formato de salida debe mantenerse consistente en todos los casos de uso equivalentes.
- **RNF17.** Comprensibilidad de mensajes de excepción
  Cuando ocurra un error o análisis parcial, el sistema debe informar la limitación en lenguaje claro y sin ambigüedad.
  Criterio de verificación: el 100% de los escenarios de error definidos en pruebas debe generar mensajes entendibles y accionables.
- **RNF18.** Facilidad de consulta manual
  La consulta individual de una URL debe poder realizarse con el menor número posible de pasos dentro del flujo principal del sistema.
  Criterio de verificación: el análisis manual debe completarse en un flujo lineal de ingreso, ejecución y visualización del resultado, sin pasos redundantes.
- **RNF19.** Trazabilidad visible del análisis
  El usuario debe poder identificar qué reglas influyeron en la clasificación final.
  Criterio de verificación: el 100% de los resultados debe permitir visualizar las reglas activadas o factores equivalentes que justifiquen la decisión.

Escalabilidad

- **RNF20.** Escalabilidad funcional del catálogo de marcas
  El sistema debe soportar el crecimiento del catálogo de marcas sin requerir rediseño funcional ni cambios en la lógica principal de análisis.
  Criterio de verificación: la incorporación de nuevas marcas, dominios oficiales y palabras clave debe realizarse mediante actualización del catálogo, sin alterar el flujo de negocio.
- **RNF21.** Escalabilidad del volumen de entrada
  El sistema debe poder incrementar el número de dominios procesados por lote manteniendo el mismo flujo de análisis y clasificación.
  Criterio de verificación: en pruebas comparativas con lotes crecientes definidos para el proyecto, el sistema debe mantener funcionamiento estable y resultados consistentes.
- **RNF22.** Escalabilidad por crecimiento de reglas
  El sistema debe permitir agregar, modificar o desactivar reglas de scoring sin afectar la estructura general del proceso de evaluación.
  Criterio de verificación: al incorporar nuevas reglas configurables, no debe requerirse redefinir los casos de uso principales del sistema.

Mantenibilidad

- **RNF23.** Configuración externa de reglas
  Las reglas de negocio y sus pesos deben estar definidas de forma parametrizable y separadas de la lógica principal del sistema.
  Criterio de verificación: al menos el 100% de las reglas de scoring debe poder identificarse, revisarse y ajustarse sin reescribir el flujo funcional del análisis.
- **RNF24.** Catálogo de marcas mantenible
  El catálogo de marcas debe estructurarse de forma clara, consistente y actualizable,

incluyendo dominios oficiales, palabras clave y patrones asociados.
Criterio de verificación: toda marca registrada debe seguir una estructura homogénea y validable antes de ser utilizada por el sistema.

- **RNF25.** Modularidad del sistema
  Las funciones de validación, análisis estructural, scoring, consulta de contenido y presentación de resultados deben estar separadas lógicamente para facilitar su modificación.
  Criterio de verificación: en revisión de diseño, cada módulo debe tener responsabilidad delimitada y dependencias controladas.
- **RNF26.** Trazabilidad entre requerimientos y reglas
  Cada regla de análisis y cada salida relevante del sistema debe poder relacionarse con requerimientos funcionales y reglas de negocio definidos.
  Criterio de verificación: la documentación del sistema debe incluir una matriz de trazabilidad verificable entre requerimientos, reglas y resultados.
- **RNF27.** Facilidad de prueba
  El sistema debe permitir validar de manera independiente las reglas de análisis y la clasificación de riesgo mediante casos de prueba repetibles.
  Criterio de verificación: para cada regla definida debe existir al menos un caso de prueba positivo y uno negativo.
- **RNF28.** Consistencia determinística
  Ante la misma entrada, el mismo catálogo y la misma configuración de reglas, el sistema debe producir exactamente el mismo puntaje y la misma clasificación.
  Criterio de verificación: en pruebas repetidas sobre un mismo conjunto de URLs, el 100% de los resultados debe coincidir.
- **RNF29.** Documentación técnica suficiente
  El sistema debe contar con documentación de reglas, parámetros, flujos y criterios de clasificación suficiente para su comprensión académica y mantenimiento posterior.
  Criterio de verificación: la documentación debe cubrir al menos propósito, entradas, salidas, reglas y restricciones de cada módulo principal.
- **RNF30.** Facilidad de actualización controlada
  Las actualizaciones del catálogo y de las reglas deben poder ejecutarse sin interrumpir innecesariamente el uso normal del sistema.
  Criterio de verificación: el procedimiento de actualización debe estar definido, documentado y ser repetible dentro del entorno del proyecto.

2.3 Requerimientos SMART

Requerimiento	Criterio SMART aplicado	Justificación breve

Análisis de URL en tiempo máximo de 10 segundos	S: Tiempo de análisis por URL. M: ≤ 10 segundos por análisis. A: Factible dado el análisis limitado (sin JS ni crawling). R: Crítico para usabilidad y monitoreo en lote. T: Evaluado en cada ejecución del sistema.	Es específico y medible (tiempo), alcanzable por el alcance técnico, relevante para rendimiento y definido en cada ejecución.
Timeout de 2 segundos para análisis de contenido web	S: Tiempo máximo de consulta HTTP de contenido. M: ≤ 2 segundos. A: Viable con solicitudes simples. R: Evita bloqueos y garantiza rendimiento. T: Aplicado por cada intento de análisis de contenido.	Define claramente el límite temporal, es verificable y asegura que el sistema cumpla restricciones de eficiencia.
Clasificación determinística del riesgo	S: Consistencia de resultados ante misma entrada. M: 100% de coincidencia en ejecuciones repetidas. A: Posible con reglas fijas. R: Fundamental para confiabilidad académica.	Garantiza reproducibilidad; medible mediante pruebas repetidas y esencial para trazabilidad.

	T: Verificable en pruebas repetidas.	
Generación de explicación del resultado	S: Inclusión de reglas activadas y evidencia. M: 100% de resultados con explicación estructurada. A: Directamente derivado del scoring. R: Clave para explicabilidad del sistema. T: Evaluado en cada respuesta generada.	Asegura transparencia del sistema; es medible y directamente alineado con objetivos del proyecto.
Detección de similitud con marcas del catálogo	S: Comparación con dominios y palabras clave del catálogo. M: 100% de URLs evaluadas contra el catálogo. A: Factible con reglas definidas. R: Núcleo del enfoque de brand protection. T: Ejecutado en cada análisis.	Es central al problema; medible (todas las URLs pasan por esta validación) y alcanzable.

Procesamiento automático de dominios en lote	S: Análisis de listados diarios de dominios. M: 100% de dominios del lote procesados sin fallo crítico. A: Viable con flujo definido. R: Base del monitoreo preventivo. T: Ejecutado por cada carga diaria.	Garantiza cobertura completa del monitoreo; medible por porcentaje de procesamiento exitoso.
Manejo de errores sin interrupción del análisis	S: Continuidad ante fallos HTTP o timeout. M: 100% de errores gestionados sin caída del sistema. A: Factible con control de excepciones. R: Crítico para robustez. T: Evaluado en cada evento de error.	Asegura resiliencia; medible mediante pruebas de error controladas.
Priorización de dominios con riesgo alto	S: Identificación de dominios con mayor puntaje. M: 100% de dominios con riesgo alto clasificados y marcados. A: Directo del modelo de scoring. R: Necesario para enfoque operativo.	Permite enfoque en casos críticos; completamente medible y alineado con objetivos del sistema.

	T: Aplicado en cada ejecución de monitoreo.	
Validación de entrada de URLs	S: Verificación de formato válido. M: 100% de entradas inválidas rechazadas. A: Implementable con reglas sintácticas. R: Previene errores y análisis incorrectos. T: Aplicado en cada ingreso de URL.	Es un control básico pero crítico; medible y necesario para integridad del sistema.
Estandarización de salida del análisis	S: Formato uniforme con URL, puntaje, riesgo y explicación. M: 100% de respuestas cumplen estructura definida. A: Viable mediante plantilla de salida. R: Mejora usabilidad y trazabilidad. T: Evaluado en cada resultado generado.	Garantiza consistencia en resultados; fácil de verificar y clave para evaluación académica.

2.4 Matriz de Trazabilidad

Matriz de Trazabilidad: Necesidades de Negocio vs. Requerimientos

Necesidad	Requerimientos asociados
NB1. Identificar URLs potencialmente fraudulentas antes de la interacción del usuario	RF1, RF4, RF6, RF7, RF10, RF14, RF15, RNF10, RNF28
NB2. Detectar suplantación de marcas colombianas (brand protection)	RF5, RF6, RF7, RF8, RF9, RF22, RF27, RNF20, RNF24
NB3. Analizar grandes volúmenes de dominios recién registrados de forma automática	RF19, RF20, RF21, RF24, RNF13, RNF21
NB4. Identificar patrones técnicos de phishing en URLs (typosquatting, palabras clave, estructura)	RF4, RF7, RF8, RF9, RF10, RF11, RNF27
NB5. Generar resultados claros, explicables y trazables para el usuario	RF16, RF17, RF18, RF32, RF37, RNF15, RNF19, RNF26
NB6. Mantener consistencia y confiabilidad en los resultados del sistema	RF14, RF15, RF38, RNF28, RNF25
NB7. Operar bajo restricciones de rendimiento para análisis en tiempo real	RF12, RF13, RF28, RNF10, RNF11, RNF12
NB8. Manejar escenarios de error sin afectar la continuidad del análisis	RF13, RF28, RF29, RNF12, RNF4
NB9. Permitir consulta manual sencilla por parte de usuarios no técnicos	RF1, RF18, RF33, RNF15, RNF18
NB10. Priorizar y alertar sobre dominios de alto riesgo	RF21, RF23, RF35, RNF15

NB11. Facilitar la actualización y mantenimiento del catálogo de marcas y reglas	RF25, RF26, RNF23, RNF24, RNF30
NB12. Cumplir con principios de seguridad y buenas prácticas (OWASP)	RNF1, RNF2, RNF4, RNF8, RNF9
NB13. Garantizar uso responsable de datos y cumplimiento normativo en Colombia	RNF9, RNF6
NB14. Permitir generación de contenido informativo para concientización	RF23, RF36, RNF15

3. Uso de IA Generativa

3.1 Propósito

El uso de IA generativa en esta entrega tiene como objetivos apoyar la estructuración del problema, definir requerimientos de forma consistente, generar explicaciones interpretables para el usuario final y asistir en la identificación de reglas de negocio.

3.2 Prompts Utilizados

Prompt 0 — Inicialización de contexto

Actúa como un experto en ciberseguridad web, ingeniería de software y protección de marca (brand protection), con conocimiento específico del contexto colombiano.

A partir de este momento participarás en la construcción de un proyecto académico de arquitectura de software asistida con IA. Todas tus respuestas deben estar alineadas con buenas prácticas de ingeniería de software, principios OWASP y diseño de sistemas seguros.

CONTEXTO DEL PROYECTO:

Se está diseñando un sistema para la detección de phishing basado exclusivamente en el análisis de URLs de sitios web.

El sistema NO debe analizar correos electrónicos, SMS, malware ni otros vectores distintos a URLs.

OBJETIVO DEL SISTEMA:

Permitir a los usuarios identificar si una URL es potencialmente fraudulenta mediante:

- Análisis estructural de URLs
- Evaluación de dominios
- Detección de patrones sospechosos (typosquatting, palabras clave)
- Análisis básico de contenido web (limitado y controlado)
- Enfoque en marcas del contexto colombiano (bancos, fintech, e-commerce, retail y servicios)

FUENTE DE DATOS:

Las URLs a analizar provendrán de listados diarios de dominios recién registrados (por ejemplo, archivos TXT como los de whoisds.com).

El sistema procesará estos dominios como entrada principal para su análisis.

CATÁLOGO DE MARCAS:

Se utilizará un archivo JSON gestionado manualmente que contiene:

- Dominios oficiales
- Palabras clave principales
- Palabras secundarias
- Palabras relacionadas
- Expresiones regulares para detección de typosquatting

Este catálogo será la base del análisis de brand protection y debe ser mantenible y actualizable.

MODELO DE CLASIFICACIÓN DE RIESGO:

El sistema debe clasificar las URLs en niveles de riesgo claros, consistentes y explicables:

Bajo: dominio similar a una marca sin evidencia clara de phishing

Medio: dominio similar que incluye palabras clave sospechosas o genera urgencia/confianza

Alto: dominio que imita activamente la marca (uso del nombre, contenido relevante y/o elementos visuales asociados)

Se debe implementar un modelo de scoring basado en reglas con pesos definidos para cada criterio.

ANÁLISIS DE CONTENIDO WEB (DELIMITADO):

Debe estar claramente acotado para cumplir con el rendimiento:

- Solo elementos básicos (ej. título HTML, texto visible limitado)
- Ejecución opcional
- Timeout corto (ej. máximo 2 segundos)
- Si no se puede analizar, se debe continuar el proceso sin fallo

MANEJO DE ERRORES:

El sistema debe definir comportamientos claros ante:

- URLs inaccesibles
- Timeouts
- Errores HTTP
- Redirecciones

Ejemplo: clasificar como “riesgo desconocido” o continuar con análisis parcial, siempre con explicación.

FUNCIONALIDAD ADICIONAL:

El sistema generará alertas automáticas sobre dominios sospechosos, las cuales podrán ser publicadas en redes sociales utilizando un LLM, con fines informativos y de concientización.

RESTRICCIONES IMPORTANTES:

- No se deben considerar soluciones fuera del análisis de URLs por cuestiones de tiempo y limitar el alcance

- No se deben incluir funcionalidades fuera del alcance definido

- No se deben usar datos personales

- El sistema debe ser eficiente (tiempo de respuesta < 10 segundos por análisis)

- Se debe priorizar la explicabilidad del resultado para el usuario

- El análisis debe ser determinístico y consistente

- El alcance debe mantenerse limitado debido a que el tiempo de desarrollo es de 1 mes

CRITERIOS TÉCNICOS CLAVE:

- Definir reglas claras y cuantificables (longitud de URL, subdominios, coincidencias, etc.)

- Utilizar un modelo de scoring de riesgo basado en pesos

- Estandarizar la salida del sistema con justificación clara del resultado

- Definir listas controladas (palabras clave, TLDs riesgosos si aplica)

- Garantizar mantenibilidad del sistema (catálogo de marcas, reglas configurables)

FORMA DE RESPONDER:

- Redacción formal y estructurada

- Enfoque en entregables académicos

- Evitar generalidades

- Ser específico y aplicable al contexto colombiano

- No inventar tecnologías innecesarias

- Priorizar claridad, trazabilidad y justificación técnica

[Agrega este bloque al final de tu prompt actual]

CONSIDERACIONES ADICIONALES DE CALIDAD:

- El análisis de contenido web NO debe implicar crawling complejo ni ejecución de JavaScript.

  Debe limitarse a contenido estático accesible mediante petición HTTP simple.

- El modelo de scoring estara compuesto por reglas explícitas, cada una con: Condición clara, Peso numérico, Justificación. El resultado debe ser una suma ponderada consistente.

- Todas las salidas deben ser coherentes entre sí y permitir trazabilidad entre problema, reglas y requerimientos.

- Si no existe suficiente información para definir algo con precisión, debes indicarlo explícitamente en lugar de asumir.

- Las respuestas deben alinearse con criterios de evaluación académica:

  claridad, coherencia, trazabilidad y aplicabilidad práctica.

A partir de este contexto, responderás a diferentes solicitudes que construirán progresivamente los artefactos del sistema.

Confirma que entendiste el contexto y estás listo para continuar.

Prompt 1 — Definición del problema:

Con base en el contexto previamente definido, redacta una definición completa del problema de negocio asociado al phishing mediante sitios web en Colombia.

Incluye obligatoriamente:

- Descripción clara del problema

- Cómo operan los ataques de phishing basados en URLs

- Factores técnicos relevantes (ej: typosquatting, ingeniería social en URLs)

- Impacto en usuarios y organizaciones en Colombia

- Por qué el problema no está resuelto actualmente

Restricciones:

- No menciones correos electrónicos ni SMS

- Mantente únicamente en phishing basado en sitios web

- No propongas soluciones todavía

Formato de salida:

Texto estructurado en párrafos, listo para incluir en un documento académico.

Prompt 2 — Identificación de actores y procesos:

A partir del problema previamente definido, identifica los actores, stakeholders y procesos de negocio del sistema propuesto.

Incluye:

1. Actores del sistema (internos y externos)

2. Stakeholders relevantes en el contexto colombiano

3. Descripción de procesos de negocio:

   - Flujo de monitoreo automático

   - Flujo de consulta manual por usuario

Restricciones:

- Mantener coherencia con el sistema basado en análisis de URLs

- No agregar actores irrelevantes o fuera del alcance

- No incluir componentes técnicos innecesarios

Formato de salida:

- Tabla para actores

- Lista estructurada para stakeholders

- Flujos descritos paso a paso

Prompt 3 — Reglas de negocio y restricciones:

Con base en el sistema definido, genera un conjunto de reglas de negocio y restricciones aplicables.

Incluye:

- Reglas de negocio derivadas del análisis de URLs (dominios, patrones, palabras clave)

- Priorización de marcas colombianas

- Generación de explicaciones al usuario

Además, define:

- Restricciones normativas aplicables en Colombia (protección de datos, buenas prácticas)

- Restricciones técnicas del sistema

Restricciones:

- No incluir reglas relacionadas con correos, SMS o malware

- No incluir reglas ambiguas o difíciles de implementar

Formato:

- Lista numerada de reglas de negocio (RN)

- Lista separada de restricciones (normativas y técnicas)

Prompt 4 — Requerimientos funcionales

A partir de todo el contexto definido previamente, genera los requerimientos funcionales del sistema.

Condiciones:

- Deben ser completos, coherentes y no redundantes

- Deben cubrir:

  - Ingreso y análisis de URLs

  - Monitoreo automático de dominios

  - Detección de patrones sospechosos

  - Generación de explicaciones

  - Interfaz de usuario

Restricciones:

- No incluir funcionalidades fuera del alcance (ej: extensiones de navegador, análisis de emails)

- No incluir detalles de implementación técnica

Formato:

Lista numerada (RF1, RF2, ...) con descripción clara y concreta.

Prompt 5 — Requerimientos no funcionales

Define los requerimientos no funcionales del sistema con énfasis en calidad, seguridad y rendimiento.

Incluye:

- Seguridad (alineado con OWASP)

- Rendimiento

- Usabilidad

- Escalabilidad

- Mantenibilidad

Restricciones:

- Deben ser medibles o verificables

- Deben ser coherentes con el contexto académico y técnico

- No incluir conceptos vagos

Formato:

Lista numerada (RNF1, RNF2, ...) agrupada por categoría.

Prompt 6 — Requerimientos SMART

A partir de los requerimientos definidos, selecciona los más relevantes y exprésalos bajo criterios SMART (Specific, Measurable, Achievable, Relevant, Time-bound).

Condiciones:

- No todos los requerimientos deben transformarse, solo los más críticos

- Cada requerimiento debe indicar claramente por qué cumple SMART

Formato:

Tabla con:

- Requerimiento

- Criterio SMART aplicado

- Justificación breve

Prompt 7 — Matriz de trazabilidad

Construye una matriz de trazabilidad inicial que relacione:

- Necesidades del negocio
- Requerimientos funcionales y no funcionales

Condiciones:

- Debe existir coherencia directa entre problema y requerimientos
- No incluir relaciones forzadas o artificiales

Formato:

Tabla con:

- Necesidad
- Requerimientos asociados

Prompt 8 — Validación asistida

Actúa como un revisor experto en ingeniería de software.

Evalúa críticamente los requerimientos y artefactos generados previamente.

Incluye:

- Identificación de inconsistencias
- Posibles omisiones
- Ambigüedades detectadas
- Recomendaciones de mejora

Restricciones:

- No reescribas todo

- Enfócate en análisis crítico

Formato:

Lista estructurada por tipo de hallazgo

3.3 Validación

Los resultados generados mediante IA fueron validados mediante revisión manual, ajuste según contexto colombiano y refinamiento iterativo de los prompts.

3.4 Evaluación Crítica

Ventajas:

- Acelera la generación de artefactos
- Mejora la claridad de documentación
- Facilita la estructuración del problema

Limitaciones:

- No reemplaza el análisis técnico humano
- Puede generar información genérica
- Requiere validación constante